Legislation

SECTION 899-AA

Notification; person without valid authorization has acquired private information

General Business (GBS) CHAPTER 20, ARTICLE 39-F

§ 899-aa. Notification; person without valid authorization has
acquired private information. 1. As used in this section, the following
terms shall have the following meanings:

(a) "Personal information" shall mean any information concerning a
natural person which, because of name, number, personal mark, or other
identifier, can be used to identify such natural person;

(b) "Private information" shall mean either:
(i) personal information

of personal information plus the data element is not encrypted, or is
encrypted with an encryption key that has also been accessed or

(2) driver's license number or non-driver identification card number;

(3) account number, credit or debit card number, in combination with any required security code, access code, password or other information that would permit access to an individual's financial account;

(4) account number, credit or debit card number, if circumstances exist wherein such number could be used to access an individual's financial account without additional identifying information, security code, access code, or password; or

(5) biometric information, meaning data generated by electronic measurements of an individual's unique physical characteristics, such as a fingerprint, voice print, retina or iris image, or other unique physical representation or digital representation of biometric data which are used to authenticate or ascertain the individual's identity; or

(6) medical information, meaning any information regarding an individual's medical history, mental or physical condition, or medical treatment or diagnosis by a health care professional; or

(7) health insurance information, meaning an individual's health insurance policy number or subscriber identification number, any unique identifier used by a health insurer to identify the individual or any information in an individual's application and claims history, including but not limited to, appeals history; or

(ii) a user name or e-mail address in combination with a password or security question and answer that would permit access to an online account.

state, or local government records.

(c) "Breach of the security of the system"

compromises the security, confidentiality, or integrity of private information maintained by a business. Good faith access to, or acquisition of, private information by an employee or agent of the business for the purposes of the business is not a breach of the security of the system, provided that the private information is not used or subject to unauthorized disclosure.

In determining whether information has been accessed, or is reasonably believed to have been accessed, by an unauthorized person or a person without valid authorization, such business may consider, among other factors, indications that the information was viewed, communicated with, used, or altered by a person without valid authorization or by an unauthorized person.

In determining whether information has been acquired, or is reasonably believed to have been acquired, by an unauthorized person or a person without valid authorization, such business may consider the following factors, among others:

(1) indications that the information is in the physical possession and control of an unauthorized person, such as a lost or stolen computer or other device containing information; or

(2) indications that the information has been downloaded or copied; or

(3) indications that the information was used by an unauthorized person, such as fraudulent accounts opened or instances of identity theft reported.

(d) "Consumer reporting agency" shall mean any person which, for monetary fees, dues, or on a cooperative nonprofit basis, regularly engages in whole or in part in the practice

any means or facility of interstate commerce for the purpose of preparing or furnishing consumer reports.

required to make a notification
under subdivision two of this section.

2. Any person or business which owns or
licenses computerized data
which includes private information shall
disclose any breach of the
security of the system following discovery
or notification of the breach
in the security of the system to any
resident of New York state whose
private information was, or is reasonably
believed to have been,
accessed or acquired by a person without
valid authorization. The
disclosure shall be made in the most
expedient time possible and without
unreasonable delay, provided that such
notification shall be made within
thirty days after the breach has been
discovered, except for the
legitimate needs of law enforcement, as
provided in subdivision four of
this section.

(a) Notice to affected persons under this
section is not required if
the exposure of private information was an
inadvertent disclosure by
persons authorized to access private
information, and the person or
business reasonably determines such
exposure will not likely result in
misuse of such information, or financial
harm to the affected persons or
emotional harm in the case of unknown
disclosure of online credentials
as found in subparagraph (ii) of paragraph
(b) of subdivision one of
this section. Such a determination must be
documented in writing and
maintained for at least five years. If the
incident affects over five
hundred residents of New York, the person
or business shall provide the
written determination to the state
attorney general within ten days
after the determination.

(b) If notice of the breach of the security of
the system is made to
affected persons pursuant to the breach

provided to the state attorney general, the
department of state and the
division of state police pursuant to

(i) regulations promulgated pursuant to Title V of the federal Gramm-Leach-Bliley Act (15 U.S.C. 6801 to 6809), as amended from time to time;

(ii) regulations implementing the Health Insurance Portability and Accountability Act of 1996 (45 C.F.R. parts 160 and 164), as amended from time to time, and the Health Information Technology for Economic and Clinical Health Act, as amended from time to time;

(iii) part five hundred of title twenty-three of the official compilation of codes, rules and regulations of the state of New York, as amended from time to time; or

(iv) any other data security rules and regulations of, and the statutes administered by, any official department, division, commission or agency of the federal or New York state government as such rules, regulations or statutes are interpreted by such department, division, commission or agency or by the federal or New York state courts.

3. Any person or business which maintains computerized data which includes private information which such person or business does not own shall notify the owner or licensee of the information of any breach of the security of the system immediately, provided that such notification shall be made within thirty days following discovery, if the private information was, or is reasonably believed to have been, accessed or acquired by a person without valid authorization.

4. The notification required by this section may be delayed if a law enforcement agency determines that such notification impedes a criminal

5. The notice required by this section shall be directly provided to

(b) electronic notice, provided that the person to whom notice is required has expressly consented to receiving said notice in electronic form and a log of each such notification is kept by the person or business who notifies affected persons in such form; provided further, however, that in no case shall any person or business require a person to consent to accepting said notice in said form as a condition of establishing any business relationship or engaging in any transaction.

(c) telephone notification provided that a log of each such notification is kept by the person or business who notifies affected persons; or

(d) substitute notice, if a business demonstrates to the state attorney general that the cost of providing notice would exceed two hundred fifty thousand dollars, or that the affected class of subject persons to be notified exceeds five hundred thousand, or such business does not have sufficient contact information. Substitute notice shall consist of all of the following:

(1) e-mail notice when such business has an e-mail address for the subject persons, except if the breached information includes an e-mail address in combination with a password or security question and answer that would permit access to the online account, in which case the person or business shall instead provide clear and conspicuous notice delivered to the consumer online when the consumer is connected to the online account from an internet protocol address or from an online location which the person or business knows the consumer customarily uses to access the online account;

6. (a) whenever the attorney general shall believe from evidence

the state of New York, in a court of justice having jurisdiction to issue an injunction, to enjoin and restrain the continuation of such violation. In such action, preliminary relief may be granted under article sixty-three of the civil practice law and rules. In such action the court may award damages for actual costs or losses incurred by a person entitled to notice pursuant to this article, if notification was not provided to such person pursuant to this article, including consequential financial losses. Whenever the court shall determine in such action that a person or business violated this article knowingly or recklessly, the court may impose a civil penalty of the greater of five thousand dollars or up to twenty dollars per instance of failed notification, provided that the latter amount shall not exceed two hundred fifty thousand dollars.

(b) the remedies provided by this section shall be in addition to any other lawful remedy available.

(c) no action may be brought under the provisions of this section unless such action is commenced within three years after either the date on which the attorney general became aware of the violation, or the date of notice sent pursuant to paragraph (a) of subdivision eight of this section, whichever occurs first. In no event shall an action be brought after six years from the date of discovery of the breach of private information by the company unless the company took steps to hide the breach.

7. Regardless of the method by which notice is provided, such notice shall include contact information for the person or business making the notification, the telephone numbers and websites of the relevant state

information that were, or are reasonably believed to have been, accessed or acquired by a person

reasonably believed to have been, so accessed or acquired.

8. (a) In the event that any New York residents are to be notified, the person or business shall notify the state attorney general, the department of state, the division of state police, and the department of financial services as to the timing, content and distribution of the notices and approximate number of affected persons and shall provide a copy of the template of the notice sent to affected persons; provided, however, that notice to the department of financial services shall only be required if the person or business is a covered entity, as defined in 23 NYCRR 500.1, and provided further that such notice shall be provided to the department of financial services in compliance with 23 NYCRR 500.17. Such notice shall be made without delaying notice to affected New York residents.

(b) In the event that more than five thousand New York residents are to be notified at one time, the person or business shall also notify consumer reporting agencies as to the timing, content and distribution of the notices and approximate number of affected persons. Such notice shall be made without delaying notice to affected New York residents.

9. Any covered entity required to provide notification of a breach, including breach of information that is not "private information" as defined in paragraph (b) of subdivision one of this section, to the secretary of health and human services pursuant to the Health Insurance Portability and Accountability Act of 1996 or the Health Information Technology for Economic and Clinical Health Act, as amended from time to time, shall provide such notification to the state attorney general within five business days of notifying the secretary.

10. The provisions of this section shall be exclusive and shall preempt any provisions of local law, ordinance or code, and no locality shall impose requirements that are

NYSENATE.GOV

Follow the New York State Senate

NEWS & ISSUES

SENATORS & COMMITTEES

BILLS & LAWS

BUDGET

EVENTS

ABOUT THE SENATE

CONTACT THE SENATE

REPORT A WEBSITE ISSUE

HOME RULE FORM

SITE POLICIES

ABOUT THIS WEBSITE

GET INVOLVED